

Министерство образования Республики Беларусь

Учреждение образования
«БЕЛОРУССКИЙ ГОСУДАРСТВЕННЫЙ УНИВЕРСИТЕТ
ИНФОРМАТИКИ И РАДИОЭЛЕКТРОНИКИ»

Факультет информационных технологий и управления
Кафедра интеллектуальных информационных технологий

Лабораторная работа №4

по дисциплине «Проектирование защищенных интеллектуальных
информационных систем»

на тему «Безопасность работы удалённых серверов в сети Internet.
Часть 1. Анализ запросов из сети Internet»

Выполнил студент гр. 321701

Ковальчук В. Н.
Самович В. М.

Проверил

Сальников Д. А.

Минск 2026

Цель: получить практические навыки анализа защищённости реального удалённого сервера, доступного из сети Internet по SSH и HTTP(S), на основании данных, накапливаемых системами журналирования в течение нескольких дней естественной эксплуатации.

Задание:

- а) Установить на удалённом сервере веб-сервер и разместить на нём тестовую страницу, доступную из сети Internet.
- б) Настроить систему журналирования на веб-сервере.
- в) Выполнить анализ данных логов различных подсистем, в том числе SSH и веб-сервера удалённого сервера, за несколько дней.
- г) Оформить отчёт о проделанной работе.

Постановка задачи. В качестве удалённого сервера используется виртуальный сервер (VPS) под управлением Ubuntu 24.04 с публичным IP-адресом и доменным именем `test-lab4.work.gd`. В роли веб-сервера выбран **Caddy** – он раздаёт тестовую страницу (одностраничное приложение на React) по протоколу HTTPS с автоматически выпущенным сертификатом Let's Encrypt. Сервер намеренно оставлен доступным из интернета без дополнительного ограничения на несколько дней: вход `root` по SSH и аутентификация по паролю оставлены включёнными (`PermitRootLogin yes`, `PasswordAuthentication yes`), а сам администратор подключается по ключу через VPN (адрес `10.0.0.4`), – чтобы в логах SSH-демона и веб-сервера накопился настоящий фоновый интернет-трафик (автоматические сканеры, попытки подбора пароля и т. п.), а не искусственно смоделированные обращения.

Краткое описание веб-сервера

Caddy – веб-сервер общего назначения, отличительная черта которого – автоматическое получение и продление TLS-сертификатов (протокол ACME, по умолчанию Let's Encrypt) без отдельного инструмента вроде `certbot`: сертификат запрашивается и обновляется самим процессом сервера при старте и по мере истечения срока действия. На сервере `test-lab4.work.gd` **Caddy** раздаёт статическую сборку одностраничного React-приложения (тестовая страница лабораторной работы), автоматически перенаправляет запросы с HTTP на HTTPS и записывает каждый запрос в структурированный лог в формате JSON (`/var/log/caddy/access.log`) с ротацией по размеру файла. Конфигурация задаётся декларативным **Caddyfile** и хранится в репозитории лабораторной работы (**Lab4.1-WebServer**) отдельно от самого сервера, что позволяет пересоздать развёртывание с нуля.

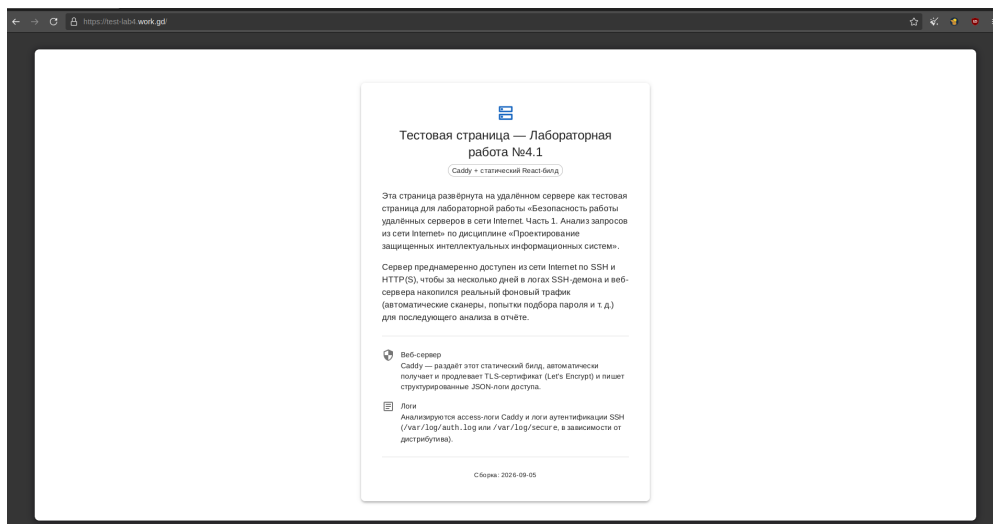


Рисунок 1 – Тестовая страница, открытая в браузере по адресу <https://test-lab4.work.gd/>

Краткое описание анализируемых файлов

– `/var/log/auth.log` – журнал аутентификации ОС (Ubuntu/Debian; на CentOS/RHEL аналогичную роль играет `/var/log/secure`), куда демон `sshd` через `syslog/rsyslog` записывает каждую попытку входа: успешную (`Accepted publickey/password`) и неуспешную (`Failed password, Invalid user`), с указанием имени пользователя, IP-адреса источника, времени и способа аутентификации. Это основной источник данных для анализа попыток подбора учётных данных по SSH.

– `/var/log/caddy/access.log` – журнал доступа веб-сервера, одна строка JSON на каждый HTTP(S)-запрос: IP клиента, метод, путь, код ответа, заголовок `User-Agent`, время обработки запроса. Позволяет отличить обращения реальных пользователей от автоматических сканеров и ботов по характерным путям запроса (например, попытки достучаться до путей вроде `/wp-admin`, административных панелей хостинг-провайдеров и т. п., которых на самой странице не существует) и по строке `User-Agent`.

Анализ запросов из сети на SSH сервер и веб-сервер

Исходные данные. Журнал SSH (`/var/log/auth.log`) охватывает период с 3 сентября 19:41 (первая запись – создание учётных записей при разворачивании сервера) до 5 сентября 19:16 UTC, когда был запущен OSSEC (см. отчёт по лабораторной работе №4.2), то есть $\approx 47,6$ ч. Журнал веб-сервера начинается только 5 сентября в 18:49:54 UTC – в день публикации сайта – и до запуска OSSEC охватывает всего 26 минут, поэтому

веб-выборка мала и пригодна лишь для качественных выводов. Все времена приведены в UTC. Анализ выполнен скриптом `analyze_logs.py` (входит в `Lab4.1-WebServer/analysis`) с запуском непосредственно на сервере; сырые записи приведены в листинг 1, сводки – в листинг 2 и листинг 3.

```

1 == /var/log/auth.log (SSH) ==
2 2026-09-04T03:39:37.999168+00:00 weaselcloud-3522 sshd[4729]: Failed password for root from 36.69.158.203 port
   ↪ 36210 ssh2
3 2026-09-04T03:39:42.639743+00:00 weaselcloud-3522 sshd[4731]: Failed password for root from 36.69.158.203 port
   ↪ 38070 ssh2
4 2026-09-05T02:56:46.780373+00:00 weaselcloud-3522 sshd[73954]: Invalid user  from 45.153.34.235 port 57998
5 2026-09-20T00:05:19.628712+00:00 weaselcloud-3522 sshd[335272]: Failed password for invalid user hduser from
   ↪ 109.160.32.83 port 35410 ssh2
6
7 == /var/log/caddy/access.log (selected fields of the JSON records) ==
8 {"ts": 1788634194.214, "client_ip": "195.178.110.211", "method": "GET", "host": "test-lab4.work.gd", "uri":
   ↪ "/", "ua": "Mozilla/5.0 (compatible; CT-WP-Scanner/1.0; +https://example.com/bot)", "status": 200, "size":
   ↪ 332, "duration": 0.0097}
9 {"ts": 1788634226.394, "client_ip": "165.227.39.235", "method": "GET", "host": "test-lab4.work.gd", "uri":
   ↪ "/", "ua": "Mozilla/5.0 (19scan/2.0.9383e293e2239313e2231323; +https://leakix.net)", "status": 308,
   ↪ "size": 0, "duration": 8e-05}
10 {"ts": 1788634227.399, "client_ip": "165.227.39.235", "method": "GET", "host": "test-lab4.work.gd", "uri":
   ↪ "/console/", "ua": "Mozilla/5.0 (19scan/2.0.9383e293e2239313e2231323; +https://leakix.net)", "status":
   ↪ 308, "size": 0, "duration": 9e-05}

```

Листинг 1 – Примеры записей анализируемых журналов

SSH. За 47,6 ч зафиксировано 13 458 неудачных попыток аутентификации (≈ 283 в час), из них 13 453 – по паролю. Ещё 2 975 попыток сделаны под несуществующими именами (`Invalid user`), а 12 190 соединений были оборваны нападающим до завершения аутентификации (`[preauth]`) – то есть большая часть сканеров даже не доходит до ввода пароля. Попытки исходили с 64 уникальных IP-адресов.

Показатель	Значение
Неудачных попыток входа	13 458 (283 в час)
Уникальных IP-адресов-источников	64
Самый активный адрес	36.69.158.203: 7 002 попытки (52 % всех)
Остальные адреса из первой пятёрки	784, 784, 501, 501 попытка
Попытки под именем <code>root</code>	9 652 (71,7 %)
Следующие по частоте имена	<code>admin</code> (567), <code>user</code> (204), <code>deploy</code> (169), <code>ubuntu</code> (165), <code>test</code> (113)
Неудачных попыток за 4 сентября	9 107 (7 002 из них – один адрес)
Уровень без учёта самого активно-го адреса	≈ 136 в час

Таблица 1 – Сводка попыток входа по SSH до включения системы предотвращения вторжений

```

1 Log analysis window: start .. 2026-09-05T19:16 generated 2026-09-20 21:21
2 =====
3 SSH (/var/log/auth.log*)
4 =====
5 Period covered by data: 2026-09-03 .. 2026-09-05
6 Failed authentication attempts: 13458 (by method: {'password': 13453, 'none': 5})
7 'Invalid user' events (unknown login name): 2975
8 Connections dropped before authentication ([preauth]): 12190
9 Unique source IPs with failed attempts: 64
10 Successful logins: 44
11
12 Failed attempts per day:
13 2026-09-03 19
14 2026-09-04 9107
15 2026-09-05 4332
16
17 Top 10 source IPs (failed attempts):
18 7002 36.69.158.203
19 784 45.153.34.235
20 784 91.92.42.52
21 501 91.92.40.45
22 501 91.92.40.27
23 381 45.119.214.98
24 320 176.53.159.197
25 274 176.53.159.198
26 235 47.251.126.207
27 225 119.6.54.138
28
29 Top 10 attacked user names:
30 9652 root
31 567 admin
32 204 user
33 169 deploy
34 165 ubuntu
35 113 test
36 79 user2
37 59 ftpuser
38 49 ec2-user
39 44 user1
40
41 Attempts against 'root': 9652 (71.7% of all failed attempts)
42
43 Successful logins by (method, user, source IP) -- verify each is you:
44 38 publickey root 10.0.0.4
45 4 password root 37.214.57.***
46 2 password root 10.0.0.4
47
48 IPs seen in the successful-login list AND the failed list (possible compromise or typo):
49 37.214.57.*** failed=3

```

Листинг 2 – Сводка по журналу SSH за 3–5 сентября (до запуска OSSEC)

Распределение по времени суток не имеет выраженного дневного профиля (активность есть в каждый час, максимумы – около 03:00 и 10:00 UTC): это признак автоматических кампаний, работающих круглосуточно, а не людей. Имя **root** остаётся главной целью, а остальные имена – типичный словарь служебных учётных записей (**admin**, **ubuntu**, **deploy**, **ftpuser**, **ec2-user**), то есть перебор идёт по общеизвестным именам, а не по сведениям об этом конкретном сервере.

Успешных входов за период 44: 38 – по ключу под **root** с адреса 10.0.0.4 (VPN администратора), 2 – по паролю с того же адреса, 4 – по паролю под **root** с одного внешнего адреса (последний октет скрыт), которому предшествовали 3 неудачные попытки; это первичная настройка

сервера администратором 3 сентября. Ни одного успешного входа с адресов, замеченных в переборе, не зафиксировано – но при включённых `PasswordAuthentication` и `PermitRootLogin` единственным барьером против 9652 попыток входа под `root` был сам пароль.

Веб-сервер. За 26 минут получено 122 запроса с 19 уникальных IP-адресов: 41 ответ 200, 34 – 308 (перенаправление HTTP→HTTPS), 42 – 404 (34,4%), 4 – 304, 1 – 405. Из 122 запросов 12 принадлежат самому администратору (10.0.0.4), а 61 (50%) – сканеру LeakIX, что видно по строке `User-Agent` (19scan). Обращения к несуществующим путям – `/.env`, `/config.json`, `/wp-json/`, `/xmlrpc.php`, `/console/`, `/server-status`, `/login.action`, `/___proxy_subdomain_whm/login` – это типичные «отпечатки» поиска уязвимых панелей управления, которых на тестовой странице нет и не было. Первое обращение (сканер с `User-Agent` `CT-WP-Scanner`) зафиксировано в 18:49:54 – практически сразу после запуска сервера. Показательно, что 121 из 122 запросов используют в заголовке `Host` доменное имя `test-lab4.work.gd`, а не IP-адрес: адрес сервера нигде не публиковался, поэтому наиболее вероятный источник (гипотеза) – журналы Certificate Transparency, в которые попадает каждый сертификат Let's Encrypt, выпущенный автоматически Caddy.

```

1 =====
2 CADDY (/var/log/caddy/access*.log*)
3 =====
4 Total requests: 122   response bytes: 777638
5 First request in window: ('2026-09-05T18:49:54.213626Z', '195.178.110.211', 'GET', '/', 'Mozilla/5.0
  ↳ (compatible; CT-WP-Scanner/1.0; +https://example')
6 Unique client IPs: 19
7 Successful loads of the test page ('/' -> 200): 24
8 Requests answered 404: 42 (34.4%)
9
10 Status codes: {200: 41, 304: 4, 308: 34, 404: 42, 405: 1}
11 Methods: {'GET': 109, 'HEAD': 1, 'POST': 10, 'OPTIONS': 2}
12
13 Top 10 client IPs:
14     31 147.182.149.75
15     30 165.227.39.235
16     13 64.89.161.85
17     12 10.0.0.4
18     4 203.109.63.67
19     4 162.43.240.3
20     4 146.190.40.177
21     4 44.200.182.198
22     3 195.178.110.211
23     3 104.164.173.155
24
25 Top 10 User-Agents:
26     61 Mozilla/5.0 (19scan/2.0.9383e293e2239313e2231323; +https://leakix.net)
27     16 Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/14
28     8 Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/147.0.0.0 Sa
29     8 Mozilla/5.0 (iPhone; CPU iPhone OS 26_3_0 like Mac OS X) AppleWebKit/605.1.15 (KHTML, like
30     5 Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chr
31     5 Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/12
32     4 curl/8.5.0
33     3 Mozilla/5.0 (compatible; CT-WP-Scanner/1.0; +https://example.com/bot)
34     3 okhttp/5.3.0
35     2 Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/13
36
37 Top 10 not-found paths (scanner fingerprints):
38     2 /.env
39     2 /config.json
40     1 /wp-json/
41     1 /xmlrpc.php
42     1 /console/
43     1 /server
44     1 /server-status
45     1 /about
46     1 /login.action
47     1 /___proxy_subdomain_whm/login

```

Листинг 3 – Сводка по журналу Caddy за первые 26 минут работы (до запуска OSSEC)

Рекомендации по улучшению безопасности удалённого сервера

а) Запретить удалённый вход суперпользователя (**root**) через SSH (**PermitRootLogin no**) и работать через отдельную учётную запись с повышением привилегий через **sudo** – на момент выполнения лабораторной работы **root** остаётся доступен намеренно, чтобы не исказить статистику попыток входа именно под этой учётной записью.

б) Отключить аутентификацию по паролю (**PasswordAuthentication no**), оставив только вход по публичному ключу – сам подбор пароля тогда теряет смысл вне зависимости от его сложности.

в) Ограничить набор IP-адресов, которым разрешён доступ по SSH (например, через `AllowUsers user@подсеть` или отдельное правило firewall), если круг легитимных источников подключения заранее известен.

г) Установить и настроить систему обнаружения/предотвращения вторжений (IDS/IPS) для автоматической блокировки источников, массово подбирающих пароль или сканирующих сервер – реализовано и подробно разобрано в отчёте по лабораторной работе №4.2.

д) Свести перечень открытых портов к минимально необходимому (22, 80, 443) средствами firewall и логировать заблокированные попытки подключения к остальным портам отдельно.

е) Регулярно анализировать журналы (в идеале – с автоматическим оповещением при превышении порога подозрительной активности), а не только пост-фактум, как в рамках этой лабораторной работы.

Выводы

Семантически лабораторная работа подтвердила утверждение задания о том, что любой сервер с публичным IP-адресом подвергается непрерывному фоновому сканированию и подбору паролей вне зависимости от того, что на нём размещено. Первое обращение к веб-серверу зафиксировано через несколько секунд после начала записи журнала (18:49:54 UTC), причём через доменное имя, а не по IP – то есть публикация сертификата уже сама по себе делает сервер видимым. За первые 47,6 ч по SSH накопилось 13 458 неудачных попыток с 64 уникальных адресов (≈ 283 в час), из них 71,7 % – под именем `root`; один адрес дал 52 % всех попыток. Ни один из адресов, замеченных в переборе, не получил доступа, но единственной причиной этого была стойкость пароля `root`, поскольку вход `root` и аутентификация по паролю намеренно оставлены включёнными.

С прагматической точки зрения работа показала три вещи. Во-первых, журналирование должно быть настроено до, а не после появления сервера в сети: именно поэтому данные за первые часы позволили получить базовый уровень «до» для лабораторной работы №4.2. Во-вторых, короткий базовый период ненадёжен: журнал веб-сервера до запуска OSSEC охватывает всего 26 минут, и его нельзя использовать для количественного сравнения – журналирование следовало запустить раньше, чем система защиты. В-третьих, анализ журналов даёт прямые рекомендации: запретить вход `root`, отключить пароли в пользу ключей и автоматизировать реакцию на повторяющиеся источники – реализовано и оценено в отчёте по лабораторной работе №4.2.